

PraisonAI has Cross-Workspace IDOR and Privilege Escalation via Platform API

Report Type: Weekly · Generated: May 31, 2026 05:30 UTC · Coverage: May 29 – May 31, 2026

1	0	1	0
Total Advisories	Critical	High	Medium

Executive Summary

Summary The PraisonAI Platform API has two authorization failures that together break workspace isolation. The service layer for issues and projects performs global primary-key lookups without checking workspace ownership, so any authenticated user can read, modify, and delete resources in any workspace just by swapping UUIDs in their API requests. On top of that, every member management endpoint (add, update role, remove) only requires ``min_role="member"``, which lets any workspace member promote themselves to owner and kick out the original owner. A low-privilege member of one workspace can steal data from every other workspace and take over any workspace they belong to. Both issues come from the same gap: the route layer pulls ``workspace_id`` from the URL and verifies membership, but the service layer ignores the workspace scope for resource lookups and ignores the caller's role level for member operations. The ``require_workspace_member()`` dependency does its job correctly. The

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
PraisonAI has Cross-Workspace IDOR and Privilege Escalation via Platform API —	Critical	9.8	0.0000	### Summary The PraisonAI Platform API has two authorization failures that

MITRE ATT&CK;® Coverage

ATT&CK; technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Advisory Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	—

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for PraisonAI has Cross-Workspace IDOR and Privilege Escalation via Platform API.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK; techniques.

Appendix — Report Metadata & Legal

Field	Value
Report ID	intel--271a9396e8f1
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v143.0.0 GOD-MODE
Generated At	2026-05-31T05:30:23.501871+00:00
Customer Tier	PRO
Customer Email	—
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries contact bivash@cyberdudebivash.com.